Ironclad Analytics

Defense in Depth

Part 1: Defense in Depth Overview

The concept of Defense in Depth is a cybersecurity strategy that uses multiple layers of protection to safeguard data and systems. Each layer provides a unique control mechanism, ensuring that if one defense fails, others remain active to prevent compromise. The diagram illustrates this approach through three trust zones:

1. Client/External Zone (DMZ) — Medium trust.
   This zone hosts public-facing services such as the web application server and load balancer. Firewalls restrict traffic to ports 80 and 443, and DDoS protection helps mitigate external attacks.

2. Employee/Internal Network Zone — High trust.
   Internal users like analysts and developers operate here. Controls include endpoint protection (EDR), intrusion detection systems (IDS), internal firewalls, and centralized logging. These measures detect and contain threats before they reach critical assets.

3. Administrative/Server Room Zone — Highest trust, restricted.
   This zone contains sensitive resources such as production file servers and backup storage. Access is limited through principles of least privilege, multifactor authentication (MFA), VPN requirements, and disk encryption. Physical access is also restricted.

Together, these zones form a layered defense that protects against external and internal threats, maintaining confidentiality, integrity, and availability across the organization.

1. Network Segmentation (The "Trust Zones")

Currently, a single compromised laptop could give an attacker a direct path to your server. You should split the network into at least three zones:

- **Public/DMZ Zone:** For the web application. This keeps client-facing traffic separate from your internal files.
- **Internal Staff Zone:** For the analysts and developers to work.
- **Management/Admin Zone:** A highly restricted area only for the two administrators to access the server and backups.

2. Server Hardening & Isolation

Since the server is on-premise and holds all the "crown jewels," it needs multiple layers of protection:

- **Dedicated Staging Environment:** Stop the practice of developers updating the production server directly. A staging environment allows for testing updates before they

Ironclad Analytics

Defense in Depth

go live, preventing accidental downtime or security holes.

- **Access Control:** Use the **Principle of Least Privilege.** Only the two admins should have full access. Developers and analysts should only have the specific permissions needed for their tasks.
- **Physical Security:** The "wired server room" must be locked and access-logged. Since backups are on a USB drive, that drive should be stored in a fireproof safe when not in use to prevent theft or damage.

3. Remote Work & Endpoint Security

With employees taking laptops home and using public Wi-Fi, the "perimeter" of your office no longer exists.

- **Virtual Private Network (VPN):** Require all remote employees to connect via an encrypted VPN tunnel. This prevents "man-in-the-middle" attacks on public Wi-Fi.
- **Multi-Factor Authentication (MFA):** This is the single most effective way to stop unauthorized access. Even if an employee reuses a password that gets leaked, an attacker can't get in without the second factor (like a code on their phone).
- **Endpoint Protection:** Install robust security software on all 13 laptops to detect malware or suspicious behavior before it spreads to the office network.

4. Logging and Monitoring

Because the company currently has "no centralized logging," an attacker could stay in the system for months without being noticed.

- **Centralized Log Management:** Every login attempt and file access on the server should be recorded.
- **Intrusion Detection:** Basic tools can alert you if someone is trying to "brute force" a password or if a laptop is suddenly sending massive amounts of data to an unknown IP address.

Justification:

“Defense in Depth" approach ensures that even if one layer fails (like an employee's password being stolen), the next layer (MFA or Network Segmentation) will stop the attacker.

My design for Ironclad Analytics applies these two core security principles by creating layers of protection and restricting access based on necessity..

Here is the layers I have implemented:

- Network Layer for implementing Network Segmentation.
- Access Layer by adding MFA and VPNs.
- Physical and Backup Layer Moving Backups to an Encrypted, Off-Site Cloud Storage.

Ironclad Analytics

Defense in Depth

Proposal: Secure Remote Access For Out-of-State Analysts

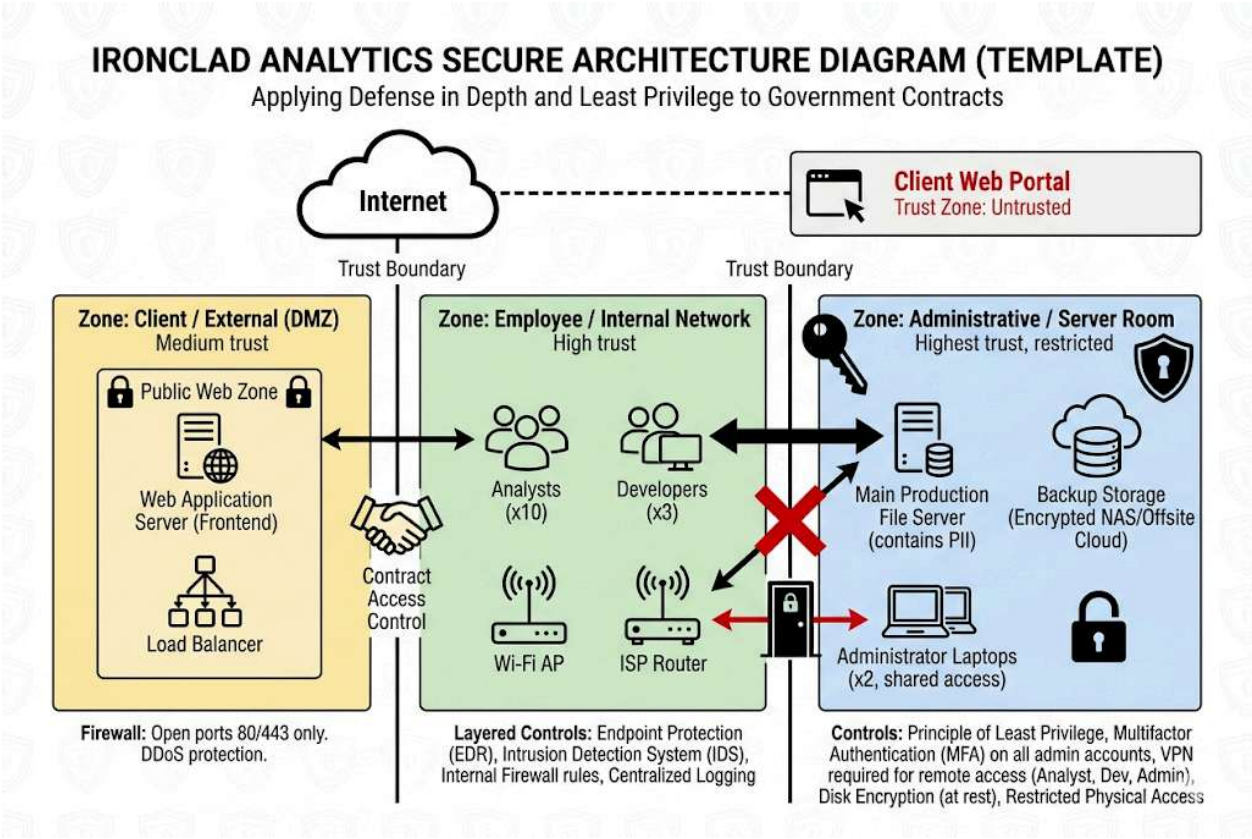
To support a distributed workflow while maintaining the security required by your government contracts, Ironclad Analytics should implement a 'Zero-Trust Remote Access' strategy. This ensures that the location of the employee does not become a vulnerability.

1. Encrypted Communication (The Tunnel):
    - Action- Implement an EnterpriseVPN
    - Why- Creates an encrypted tunnel between the remote analyst's laptop and the Ironclad's internal network. (the back & forth is shielded from "Man-in-the Middle" attacks and packet sniffing.

2. Identity Verification (The Gatekeeper):
    - Action- Enforce Phishing-Resistant Multi-Factor Authentication(MFA)
    - Why- YOu cannot physically verify who is sitting at the device, a password is not enough. Analysts should be required to use a physical security key to prove their identity before the VPN connection is established.

3. Environment Isolation (The Clean Room):
    - Action- Utilize Virtual Desktop Infrastructure (VDI)
    - Why- Instead of allowing remote analysts to download sensitive PII directly onto their device, they should log into a "Virtual Desktop" that lives on the company's server. They see the data and interact with it but the data never really leaves the secure office environment.

By combining a VPN for encryption and MFA for identity, and VDI for data isolation, Ironclad can hire talent anywhere in the country without increasing the risk of a data breach. This approach follows the 'Principle of Least Privilege'by ensuring remote users only see the data they need within a controlled virtual environment, rather than having full access to the internal physical network.

Ironclad Analytics

Defense in Depth